

Secure Network Write-up

Joshua Sosa

Network Overview

This report details the configuration of a secure network for an organization. The network uses a segmented framework of 10.z.0.0/16, where in this case $z = 12$. The network is organized into 5 zones based on user groups and security principles, the user groups are Executive, Employee, and Guest the other zones are the DMZ and the Network Management zone. These zones are segmented by VLAN and access controlled by an access control list (ACL). In this report I will explain the configuration of the network, the attack surface, and mitigation strategies.

The organizational network is segmented into 5 zones, every zone utilizes the 10.12.x.0/24 addressing scheme. The third octet represents the VLAN number, executive is 10, employee is 20, guest is 30, DMZ is 40, and network management is 50. This segmentation was done to limit the broadcast domain for efficiency, but most importantly to limit the view and connection each zone can have with the other. The Exec, employee, and guest zones have restricted access to the DHCP service, only in instances where the host in one of these zones sends out a DHCP discover request will the DHCP server provide an IP address, default gateway, and a DNS server address. Only hosts in the network management zone can view or connect with the DHCP server.

The executive zone (VLAN10) and employee zone (VLAN20): The hosts in their zone can communicate with all other zones within the network with the exception being the network management zone (VLAN50). This was done with the policy of least privilege in mind, the zone only needs to communicate with the internet and other hosts on the network, not with the network management infrastructure.

The guest zone (VLAN30): The zone is restricted in its access within the network, the guest zone only has access to communicate with other hosts in the guest zone, and the DMZ. This security measure was put into place so guests are treated as untrusted.

The DMZ (VLAN40) is where the Web and DNS servers are placed, this was done to isolate public facing services from the rest of the network. Due to this restriction the servers in the DMZ can't initiate a connection, only respond to incoming requests. The DNS server is used inside and outside of the network for DNS lookup, with two different records provided based on the point of access to account for NAT and PAT.

In the network Management zone (VLAN50) no restrictions are placed on hosts. This is the zone where network management devices are located, including the DHCP server and network controller.

The core router handles inter VLAN routing via SVI interfaces and then applies the various ACLs for their respective VLANs. The core router is also where NAT and PAT are applied to the serial interface to protect the internal network from the internet, while still allowing external access to the DMZ.

Possible Attack Surfaces

When analyzing the attack surface of the created network the first place I can see being compromised is the DMZ. The DMZ is the only public facing zone in the entire network, meaning that attackers can directly attempt to connect to the servers and compromise them. Due to this risk the DMZ has the most restrictions on it to protect from pivot attacks but there are still attacks available. If compromised a DNS server could have its DNS records spoofed resulting in hosts on the network initiating connections with malicious websites. These websites could imitate the original and result in data collection and stolen credentials. The compromised DNS server could also send encoded commands hidden in DNS responses to compromise other hosts on the network.

Another point of interest is the Core router, which is also exposed to the internet. The risk for the router would be DOS attacks, due to ports 80 and 443 being set accessible by NAT. An attacker could flood these ports with SYN requests that exhaust the router, resulting in genuine traffic not being able to be processed. This level of exhaustion will be quick to reach in this network because each and every SYN request will need to be denied by the ACLs put into place, which consumes significant router processing resources. A DoS attack could prove fatal to this network due to there being only one singular connection from the network to the ISP router, meaning if the core router goes down all zones lose internet connection and inter VLAN routing. A different kind of flooding can also happen in the network. If an attacker is able to be added to the guest zone they could flood the DHCP guest pool with spoofed DHCP Discovery packets, with the goal of exhausting the number of IP addresses able to be assigned. This would result in no new guests being able to join the guest zone.

Yet there is still one vulnerability I have not yet talked about which is the network management zone. This zone has access to and controls the entire network, meaning a single breach of this zone gives an attacker full control over the entire network. This zone does not implement encrypted communication meaning that all activities in this zone could be viewed via sniffing. An attacker could also gain access to this zone through misconfigured ports, outdated software, or physically connecting to the VLAN 50 switch.

To mitigate identified attack surfaces, I recommend the following mitigation strategies. To defend the vulnerability of the DMZ from spoofing attacks I would recommend cryptographically signing the DNS records. To counter the encoded commands in DNS responses I would install an IDS/IPS in particular snort within the network management zone. Snort can be configured to monitor traffic and alert administrators if there are malicious patterns in packets sent across the network.

To mitigate attacks to the core router I would recommend Web Application Firewalls (WAF), and a redundant ISP connection or backup router to maintain availability if the primary link is exhausted. WAF would be able to filter some malicious HTTP and HTTPS requests while rate limiting policies handle the SYN flooding attempts. Rate limiting restricts the amount of SYN requests a bot can send based on a provided timeframe. To mitigate DHCP exhaustion, DHCP snooping should be implemented. DHCP snooping involves rate limiting like WAF but also includes port verification ensuring a limitation on the amount of IP addresses one port can receive.

As for how to mitigate the attack surface of the network management zone, I would recommend first implementing HTTPS for any web based management through the network controller to ensure an encrypted connection. All the unused ports from the various switches in the management zone should also be configured as down, to prevent unwanted physical connection to the switches. There will also be snort the IDS/IPS that should be configured here to detect any unusual behavior.